INFORMATION NETWORK SECURITY ADMINISTRATION (INSA)

Cyber Security Audit and Evaluation · Guideline v1.0 (May 2015 E.C.)

CSMS audit of an information-technology product and its operating organisation

Cyber Security Audit and Evaluation Report

Auditee: Majo Bridge Technologies and Events PLC
Product: MaJo e-School Bridge (MayaBela) · multi-tenant school ERP

DOES NOT PASS

38 / 100

Maturity: Developing (Guideline §9 Table 1: 36–75) · **Certification result: FAIL**

Document number	INSA-CSMS-AUD-MB-2026-11-09
Audit date	9 November 2026 (Gregorian) · East Africa Time
Guideline used	Cyber Security Audit and Evaluation Guideline v1.0, May 2015 E.C. (INSA)
Normative criteria	CMCSRS (as referenced by the Guideline); Common Criteria (product); CIA + school-data protection; ISO/IEC 27001 control families used where CMCSRS text was not attached to this engagement
Audit type	External CSMS evaluation in the role of Regulatory Auditor (Guideline §6.2.a). Document review + source-code / configuration fieldwork. Not a legally gazetted INSA certificate.
Target of audit	People, Process, and Technology (Guideline §6.1) for the MayaBela product and the vendor operating model, including the live shared cloud project used by schools.
Period of coverage	Source tree on `origin/master` as of this audit date, plus the vendor's own security audit dated 21 October 2026 and INSA hardening migration dated 5 November 2026.
Classification	Restricted — auditee and auditor. Contains findings about children's data. Do not publish school passwords or keys.

1. Executive summary

Overall conclusion: the auditee does not pass. MaJo Bridge / MayaBela is a working school ERP with useful technical controls in source (school-scoped row security, role catalogue, login rate limits, audit-log collections, CI tests). That is not a Cyber Security Management System. Under Guideline §8.5(e), a **Major Non-Conformance** exists wherever there is significant doubt that confidentiality, integrity and availability of assets meet specified requirements, or where several related gaps show a deeper management-system failure. Five Major Non-Conformances are recorded below. The organisation therefore **cannot be certified or recertified** until those are closed and a follow-up audit is passed (Guideline §8.6).

The Evaluation Scorecard (Guideline §9) places the auditee at **38 / 100 — Developing**: "security posture is in progress… If technologies are in place, attention should be focused on processes and people." That matches the evidence. Technology is ahead of process and people. Technology is still not production-equivalent to the hardened source.

25 / 100	**33 / 100**	**48 / 100**
People	Process and structure	Technology

Weighted composite (People 30% · Process 35% · Technology 35%) = **38**.

1.1 What would be required to pass

1. Close every High finding in **production** (not only in git): teacher sensitive writes, registry edge-function role checks, driver student-registry reads, fee-payment integrity, password fields stripped from `school_registry`.
2. Establish a documented CSMS: signed policy, named cyber security officer, risk register, incident response, backup restore test, supplier agreement with the cloud host, internal audit programme.
3. Independent penetration test and a two-school isolation test that is actually run (CI must not skip).
4. Mandatory MFA for all privileged roles; children's data minimisation; data-residency statement acceptable to INSA.
5. Follow-up audit with evidence that Major NCs are closed.

2. Scope, method, and limitations

2.1 In scope

- Vendor organisation as operator of a multi-tenant school information system (children's records, marks, health/safeguarding collections, payroll, identity).
- Flutter application, Supabase schema / RLS / triggers, Edge Functions, CI workflows, and security documents in the MayaBela repository.
- Intended production cloud project `hwkiihonthueadbhcvfi` (not logged into; configuration inferred from source and the vendor's prior audit).

2.2 Out of scope

- On-site inspection of offices, server rooms, or school campuses.
- Interviews with staff, background-clearance files, and training attendance (none were provided).
- Live penetration of production (Guideline §1 allows pentest of critical systems; this engagement did not attack production).
- Common Criteria laboratory evaluation of the product (normative reference 2 — not performed).
- Each customer school's own CSMS (Fnote, LIA, etc.). Those remain separately auditable.

2.3 Methods (Guideline §8.3)

- Review of documented information: `docs/security/MAJOBRIDGE_SECURITY_AUDIT.md`, Phase 1 hardening notes, INSA permission-hardening migration, module permission matrix, CI workflow.
- Source inspection of RLS, write-guard triggers, `school-upsert-registry`, MFA settings, platform PIN hashing, rate-limit SQL.
- Use of prior automated evidence: local Postgres role-matrix tests, Deno registry-write tests, source-invariant Python checks. Live staging RLS job is designed to skip when secrets are absent.

> **Reservation (Guideline §8.5.b.8).** This is a compliance-heavy audit with limited substantive testing. Absence of a production pentest and of people/process records is itself a finding, not an excuse to assume those controls exist. Where production apply-status is unproven, the auditor treats the vendor's own statement ("migration is not applied to production") as evidence of nonconformity.

3. Context of the auditee

MayaBela is a Flutter web/mobile ERP. Persistence is a single Postgres database on a hosted Supabase project. School rows sit in `public.app_documents` keyed by `(collection, school_id, doc_id)`. The client ships an anon key. Authorisation is JWT school/role claims plus RLS and a write-guard trigger. Some writes go through Edge Functions that use the service role and therefore skip the SQL write guard.

The system stores children's identity, attendance, marks, and (by collection design) health, counselling and safeguarding notes. That is sensitive personal data of minors. INSA's people/process/technology model and the CIA triad therefore apply at a high bar. A shared foreign-hosted tenancy without a proven CSMS is not an adequate national posture for that data class.

4. Evaluation scorecard (Guideline §9)

Each control is scored 0–5 (0 inexistent · 1 ad hoc · 2 documented only · 3 implemented with material gaps · 4 minor gaps · 5 effective). Twenty controls × 5 = 100.

#	Pillar	Control (mapped to Guideline §6.1 / ISO 27001 families in lieu of unpublished CMCSRS clauses)	Score	Result
P1	People	Named cyber security officer, RACI, top-level commitment	2	App RBAC exists; no organisational CISO/CSMS owner file
P2	People	Awareness, education, personnel clearance	0	No records
P3	People	Acceptable-use / privacy culture for staff handling children's data	1	Product has consent collections; no staff programme
PR1	Process	Documented CSMS / security policy	1	Engineering notes only, not a signed CSMS
PR2	Process	Risk assessment and treatment (Guideline §7.1.1)	1	One source audit; no living risk register
PR3	Process	Asset inventory	3	Collection/module matrix exists
PR4	Process	Incident management	1	No IRP, no evidence of tabletop
PR5	Process	Business continuity / backup restore test	2	Backup collections and an on-prem playbook; no restore evidence
PR6	Process	Supplier / cloud governance (SLA, DPA, residency)	2	Hosted Supabase; no DPA/residency pack in repo
PR7	Process	Internal audit programme (Guideline §7)	1	This evaluation is the first structured CSMS audit on file
PR8	Process	Privacy, retention, disposal of children's data	2	Consent/rights collections; no retention schedule
T1	Technology	Access control (RBAC, RLS, school isolation)	3	Strong design; production not proven; High write gaps
T2	Technology	Authentication (password, MFA, rate-limit)	3	Rate-limit + optional MFA; leadership MFA only
T3	Technology	Logging and audit trail	3	School/platform/grade audit exist; stamping gaps in production
T4	Technology	Secure development and CI	3	Analyze, unit, Deno, local Postgres matrix; staging RLS skippable
T5	Technology	Cryptography and key management	2	TLS via vendor; anon key and project URL in client source
T6	Technology	Vulnerability management / penetration testing	1	No pentest report
T7	Technology	Production equals hardened source	2	INSA migration (5 Nov 2026) not applied to production

#	Pillar	Control (mapped to Guideline §6.1 / ISO 27001 families in lieu of unpublished CMCSRS clauses)	Score	Result
T8	Technology	Multi-tenant isolation (negative test)	3	Designed; live two-school test not evidenced as run
T9	Technology	Protection of minors' data (need-to-know)	2	Drivers can read whole student registry (SEC-005) still open
T10	Technology	Common Criteria / independent product evaluation	0	Not started

Sum of control scores = **38 / 100**.

Score	Maturity (Guideline Table 1)	This audit
0–35	Immature	
36–75	Developing	**38 — selected**
76–90	Mature	
91–100	Advanced	

Pass/fail rule used: Mature (76+) with **zero Major Non-Conformances** is the minimum for a pass at national CSMS evaluation. Developing with Major NCs is a fail. This audit: Developing + 5 Major NCs = **FAIL**.

5. Findings

5.1 Major Non-Conformance Reports

A Major NC substantially affects the capability of cyber security to achieve its objectives (Guideline §8.5.e.1): significant doubt that CIA of assets meets requirements, or a cluster of related minors showing governance failure.

ID	Finding	Evidence	Why major
MNC-01	**No organisational CSMS.** There is no signed cyber security policy, no appointed Cyber Security Officer, no risk register, no incident-response plan, no internal audit programme, and no personnel-clearance / awareness records.	Repository contains engineering security notes, not a CSMS. Search of docs found no IRP, ISMS, CISO charter, or training register. Guideline §6.1 requires People and Process, not only Technology.	Governance failure. Several related absences indicate the management system itself is missing (Guideline §8.5.e.1.ii).
MNC-02	**Known High technical defects remain in production.** The vendor's 21 Oct 2026 source audit listed High issues (teachers writing sensitive collections; service-role registry upsert skipping SQL guards; possible admin password in `school_registry`; classroom teachers marking fees paid). An INSA hardening migration (5 Nov 2026) and registry policy tests exist in source. The vendor recorded that the migration is **not applied to production** and the edge function is **not deployed**.	`docs/security/MAJOBRIDGE_SECURITY_AUDIT.md` (SEC-001, 002, 004, 006); `supabase/migrations/20261105120000_insa_permission_hardening.sql` header: "not applied to production".	Significant doubt that confidentiality and integrity of payroll, identity, and fee records meet requirements in the live system.
MNC-03	**Need-to-know failure on children's identity data.** A driver JWT can read the entire student registry of the school (no bus-assignment restriction). Health/safeguarding collections exist in the same database. UI hiding is not a security boundary.	SEC-005 in the vendor audit; `app_doc_readable` driver branch. Sidebar is not RLS.	Confidentiality of minors' PII. Unresolved High finding.

ID	Finding	Evidence	Why major
MNC-04	**No independent technical evaluation.** No penetration-test report, no vulnerability-scan programme, no Common Criteria evaluation (normative reference 2 of the Guideline). Staging RLS isolation is skippable in CI when secrets are unset.	`.github/workflows/ci.yml` rls-isolation job exits 0 when staging secrets are missing. No pentest artefact in `docs/`.	Cannot confirm that controls work against a skilled attacker. Guideline §1 expects pentest of computer-based systems where relevant.
MNC-05	**Data residency / supplier control of children's records is unproven.** Live schools share one hosted Supabase project. No DPA, no residency region evidence, no tested restore, no documented lawful basis pack. LIA's TOR requires an on-prem master; the default product is cloud-master.	Architecture in `lib/supabase_options.dart` (default hosted URL); absence of supplier/CSMS records; LIA on-prem guide is a future option, not current production.	Availability and sovereignty of a national-scale education dataset; CIA of assets not demonstrated under INSA supplier and BCM expectations.

5.2 Minor Non-Conformance Reports

ID	Finding	Evidence / gap
mNC-01	MFA is optional for most roles. Only school leadership is described as required. INSA-grade privileged access should be MFA for admin, platform owner, and finance.	`lib/widgets/mfa_settings_card.dart` — "opt-in for your role".
mNC-02	Teacher login still provokes denied-write storms (availability / log noise). Database denial is correct; the client should not attempt the write.	SEC-003. Not a breach; still a control-operation defect.
mNC-03	Public `school-branding` bucket and a shared setup-probe prefix writable by any authenticated user.	SEC-010.
mNC-04	Grade audit was not append-only in production (integrity of academic history). Fixed in unapplied source.	SEC-007.
mNC-05	Students could write homework rows school-wide in production (integrity). Homework bound in unapplied source only.	SEC-008.
mNC-06	Any teacher could insert a school audit row with a client-chosen actor (audit-trail integrity). Stamping exists in unapplied source.	SEC-009.
mNC-07	Anon key and production project URL are compiled into the client. Acceptable for Supabase anon keys only if RLS is perfect. RLS is not yet proven perfect in production.	`lib/supabase_options.dart`.
mNC-08	No data-retention / disposal schedule for student, health, or safeguarding collections.	No policy document.
mNC-09	Edge Functions other than registry were inventoried, not line-audited (`platform-*`, login, invite-parent, Maya chat). Service-role bypasses the SQL guard.	Vendor audit SEC-011 gap.

ID	Finding	Evidence / gap
mNC-10	Maya Assistant may send school context to an external model without a documented DPIA.	Vendor audit module inventory.

5.3 Observations / opportunities for improvement

ID	Observation
OBS-01	School-id RLS on direct table access is a sound control: JWT `app_metadata.schoolId`, case-normalised match, update cannot retarget another school. Keep it. Prove it with a live two-school negative test.
OBS-02	CI already runs Flutter analyze/tests, Deno policy tests, and a local Postgres replay of every migration (role-by-role). This is above typical startup practice. Make the staging RLS job fail-closed instead of skip.
OBS-03	Platform owner PIN uses PBKDF2-SHA256 (210,000 iterations) with upgrade-on-login from legacy SHA-256. Good direction; protect the setup secret.
OBS-04	Login rate-limit SQL, crash-report server-only tables, and password-reset codes marked server-only are appropriate patterns. Keep them.
OBS-05	The 5 Nov 2026 INSA permission-hardening migration is the correct technical response to SEC-001/004/006/007/008/009. Applying it to production after staging is the shortest path to shrinking MNC-02.
OBS-06	A dedicated on-prem instance (separate URL, separate database) is a viable path for schools that INSA or a TOR forbid from the shared cloud. It is not a substitute for a vendor CSMS.

6. Pillar commentary

6.1 People — FAIL

Guideline §6.1.a lists career paths, awareness, culture, education, clearance, privacy, roles, and top-level commitment. The product implements *application* roles (admin, teacher, parent, student, driver, platform owner). That is not personnel security. No evidence was presented of:

- a named Cyber Security Officer (Guideline §6.2.e.1);
- background screening for staff who can open all schools;
- annual awareness for engineers and school administrators;
- acceptable-use acknowledgement for children’s data.

6.2 Process and structure — FAIL

There is no CSMS to audit against the auditee’s own policy, because that policy does not exist. Risk is managed by engineering tickets and a single source-code audit. Incident response, BCM, supplier management, and an internal audit programme (Guideline §7) are not established. Asset inventory at the collection layer is a relative strength (module permission matrix).

6.3 Technology — NOT YET ADEQUATE

Technology is the strongest pillar and still insufficient for a pass. Controls in source are real: RLS, write guards, registry edge policy tests, rate limits, audit collections, optional TOTP MFA, CI. Controls in production lag source. Children’s need-to-know (drivers vs student registry) is not closed. No pentest. No CC evaluation. Multi-tenant children’s data on a single hosted project without a residency file.

7. Corrective action required before recertification

Guideline §8.6: the auditor requests information that appropriate action has been taken. Until MNC-01 to MNC-05 are closed, the result remains FAIL. Recommended order:

1. **Immediately (production safety):** apply INSA hardening migration and deploy `school-upsert-registry` to staging, run the local Postgres matrix and a two-school negative test, then production. Restrict driver reads of `student_registry`. Confirm no `adminInitialPassword` remains in live rows (count only; do not print values).
2. **30-day CSMS pack:** signed security policy; appoint a Cyber Security Officer; risk register covering children's data, multi-tenancy, and cloud supplier; incident-response one-pager with 24/7 contact; backup restore drill with minutes; MFA mandatory for platform owner, school admin, and finance.
3. **Independent test:** scoped pentest of web + API + storage; fix Critical/High; retest. Turn CI RLS isolation into fail-closed.
4. **Data protection file:** processing inventory, retention, parental consent operational procedure, Maya-chat DPIA or disable Maya on live schools until done, supplier DPA and region.
5. **Follow-up audit** against this report. Major NCs must be verified closed, not promised.

8. Statement of the auditor

This evaluation was performed in the form required by the INSA Cyber Security Audit and Evaluation Guideline v1.0 (May 2015 E.C.), acting as a Regulatory Auditor for the purpose of advising the auditee before national engagement. It is **not** a substitute for an on-site INSA inspection of a designated critical-infrastructure operator, and it does not authorise operation of the system as if certified.

Findings are evidence-based on the repository and the vendor's own unapplied-production statements. Where evidence was missing, the control was scored as not implemented (Guideline: evidence-based approach, §5.f).

Audit conclusion: MaJo e-School Bridge / MayaBela, as currently operated, **does not pass** a national CSMS audit. Maturity **Developing (38/100)**. Five Major Non-Conformances. Recertification is possible after the corrective actions in §7, not before.

Lead auditor (evaluation team)	Auditee acknowledgement (Guideline §5.h)
Name / signature / date	We have received this report and will respond with an action plan.